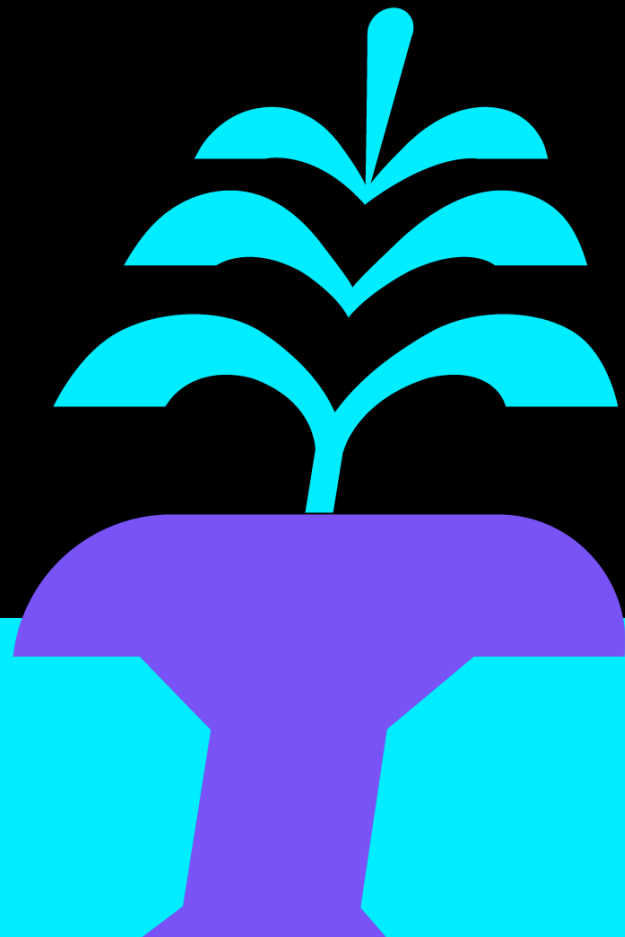




HYBRID
IDENTITY
PROTECTION
conf26





Become a Wizard of Entra Workload Identities

Eric Woodruff

Thomas Naunheim



Eric Woodruff

Chief Identity Architect, Semperis

Microsoft MVP (Identity & Access)



@ericonidentity.com



@ericonidentity



/in/ericonidentity



ericonidentity.com



Thomas Naunheim

Cyber Security Architect, glueckkanja AG

Microsoft MVP (Identity & Access, Cloud Security)



@naunheim.cloud



@Thomas_Live



/in/thomasnaunheim



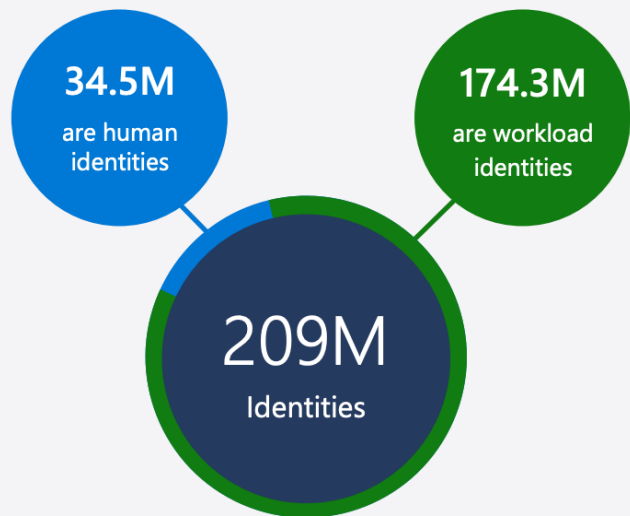
cloud-architekt.net

Agenda

- Overview of workload identities
- Policies and secure delegation for workload owners
- Real world abuses against workload identities
- Security posture and XDR threat protection



State of workload identity management



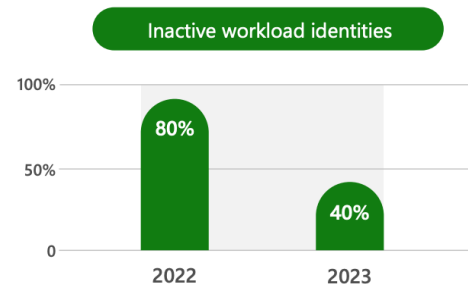
Of the 209M cloud identities identified in 2023,



There were 3 human super identities for every 7 workload super identities



Of the 174.3M workload identities identified



3% of workload identity permissions were used in 2023



HYBRID
IDENTITY
PROTECTION
conf26

Overview of workload identities

Security principals



User



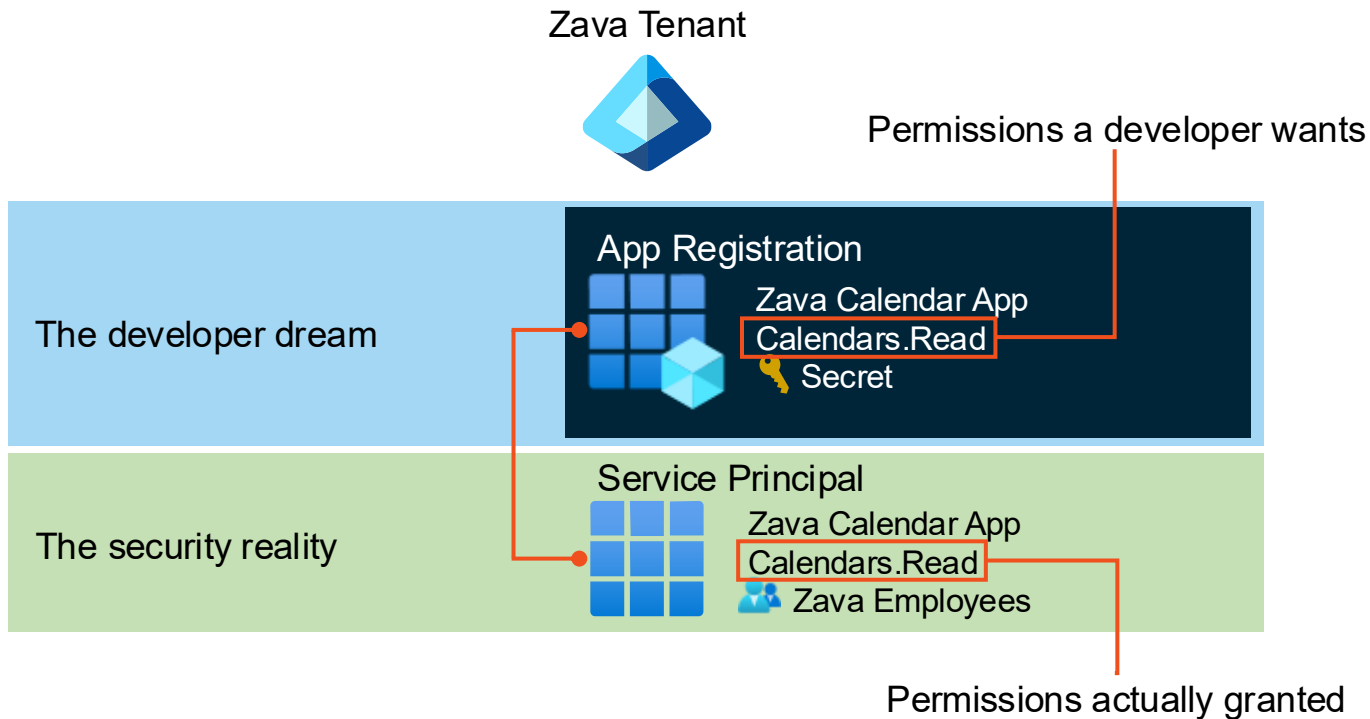
Service principal



Group

Things you can assign permissions to

App registrations



Types of service principals



Service principal



Application



ManagedIdentity



SocialIdp



Legacy

Logical types of service principals



Service principal



Microsoft



Application



OIDC Managed



Agent ID

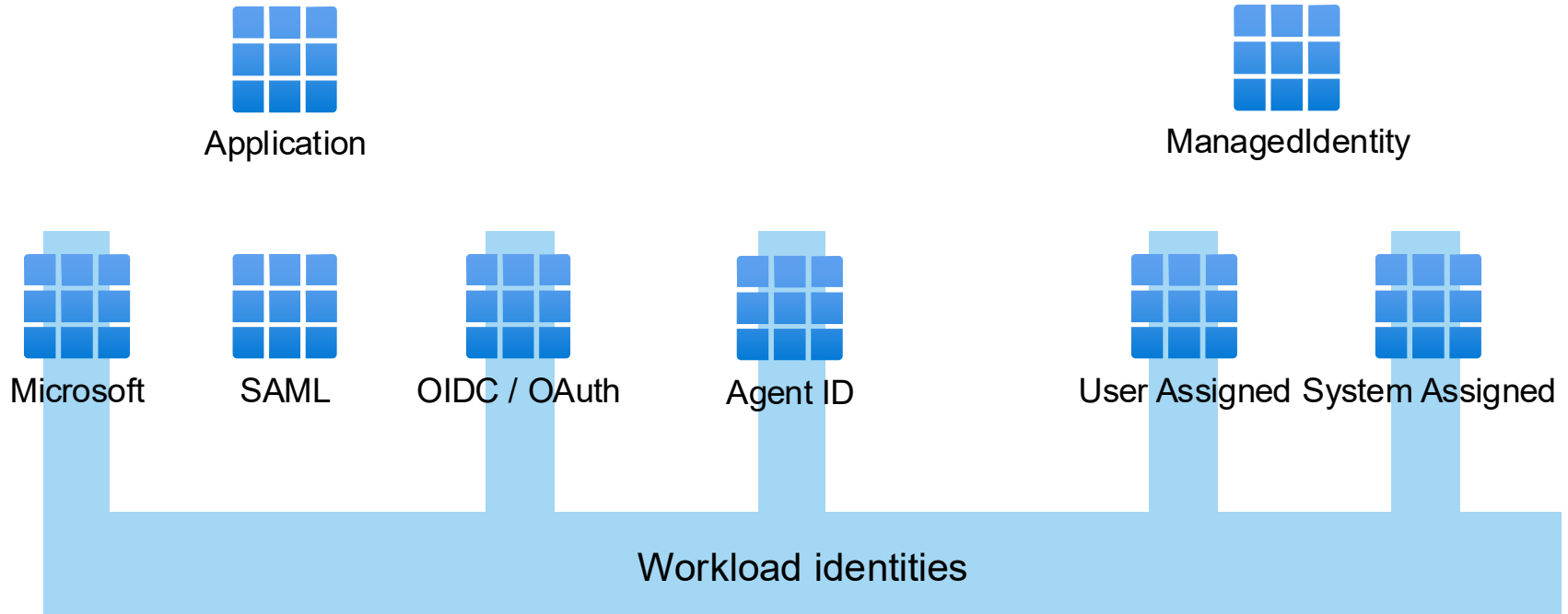


User Assigned



System Assigned

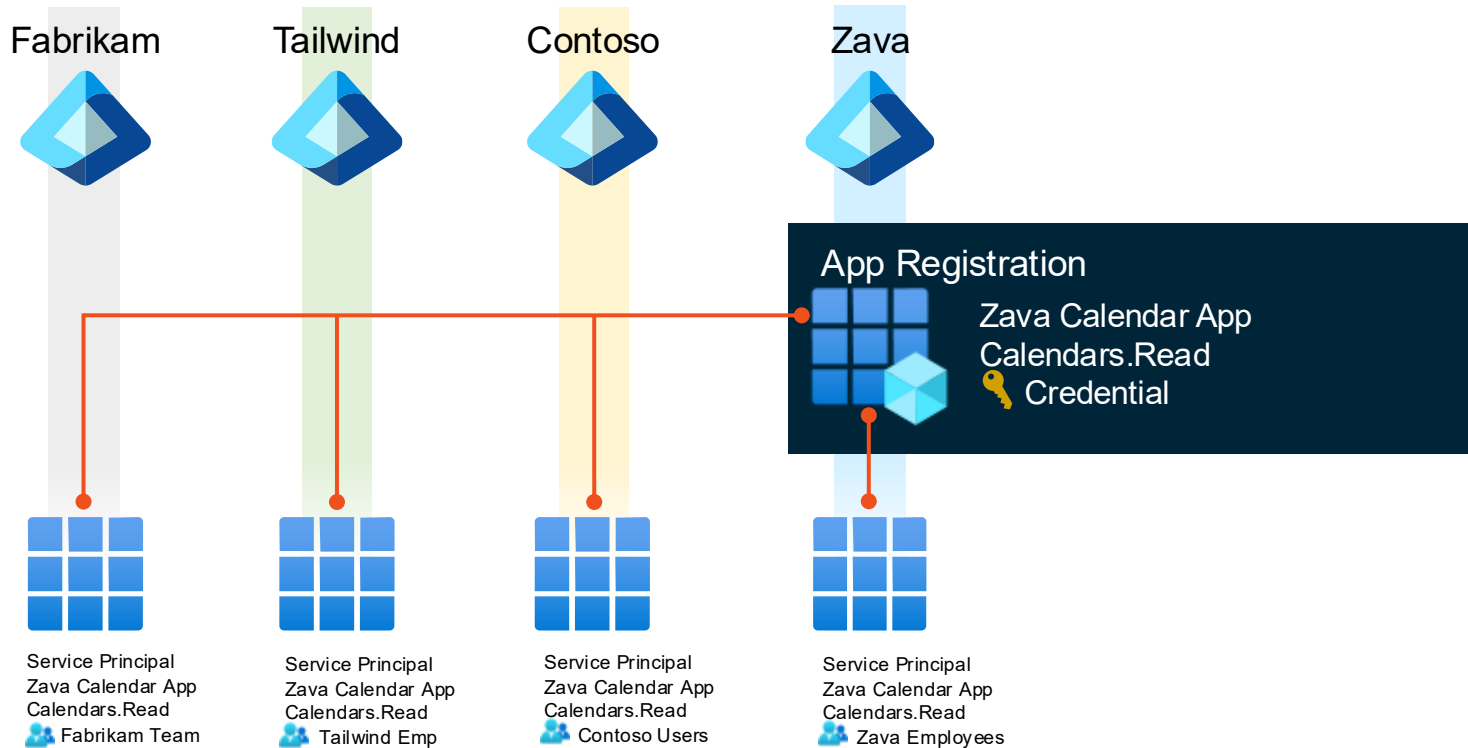
Workload identities



Single-tenant applications



Multi-tenant applications



Different types of credentials

App Registration

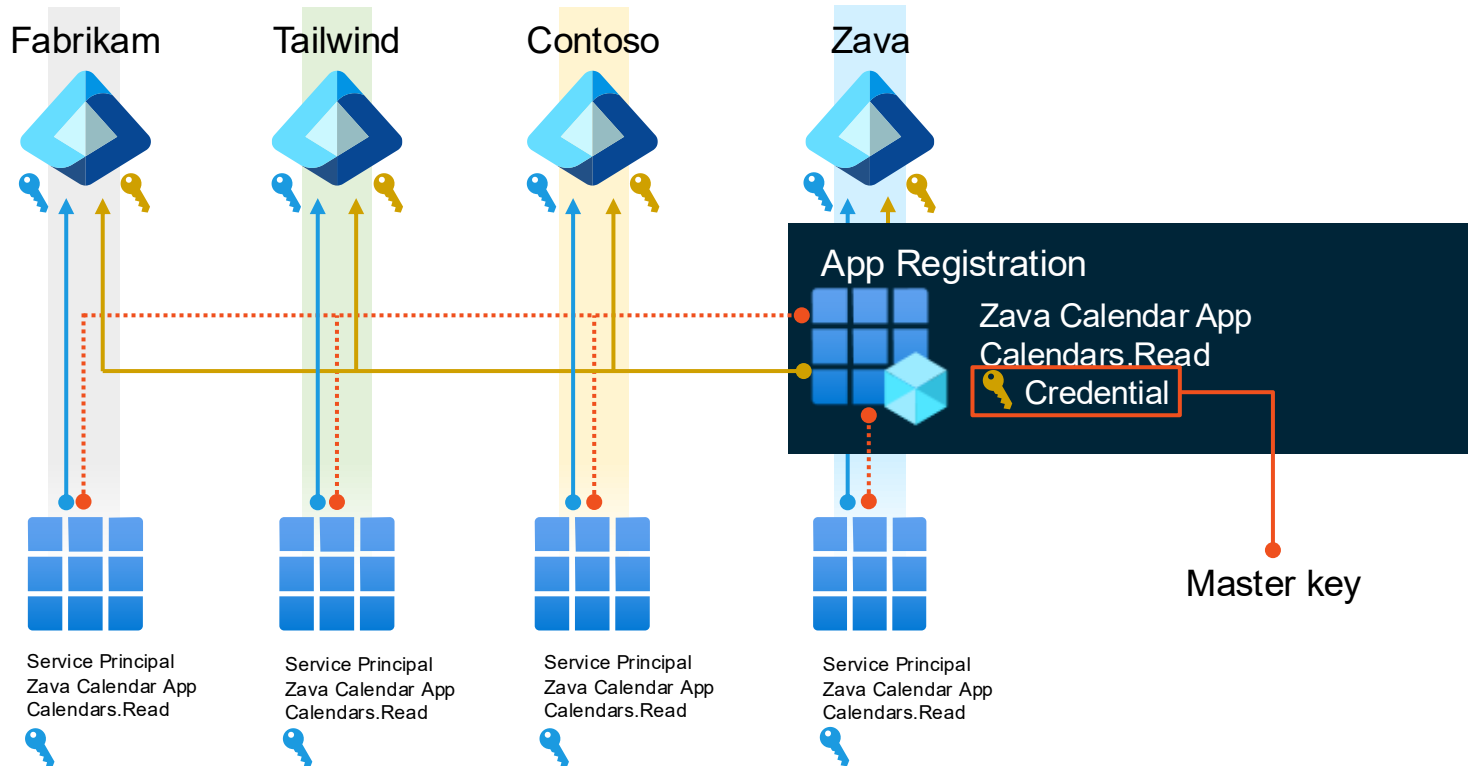


Service Principal

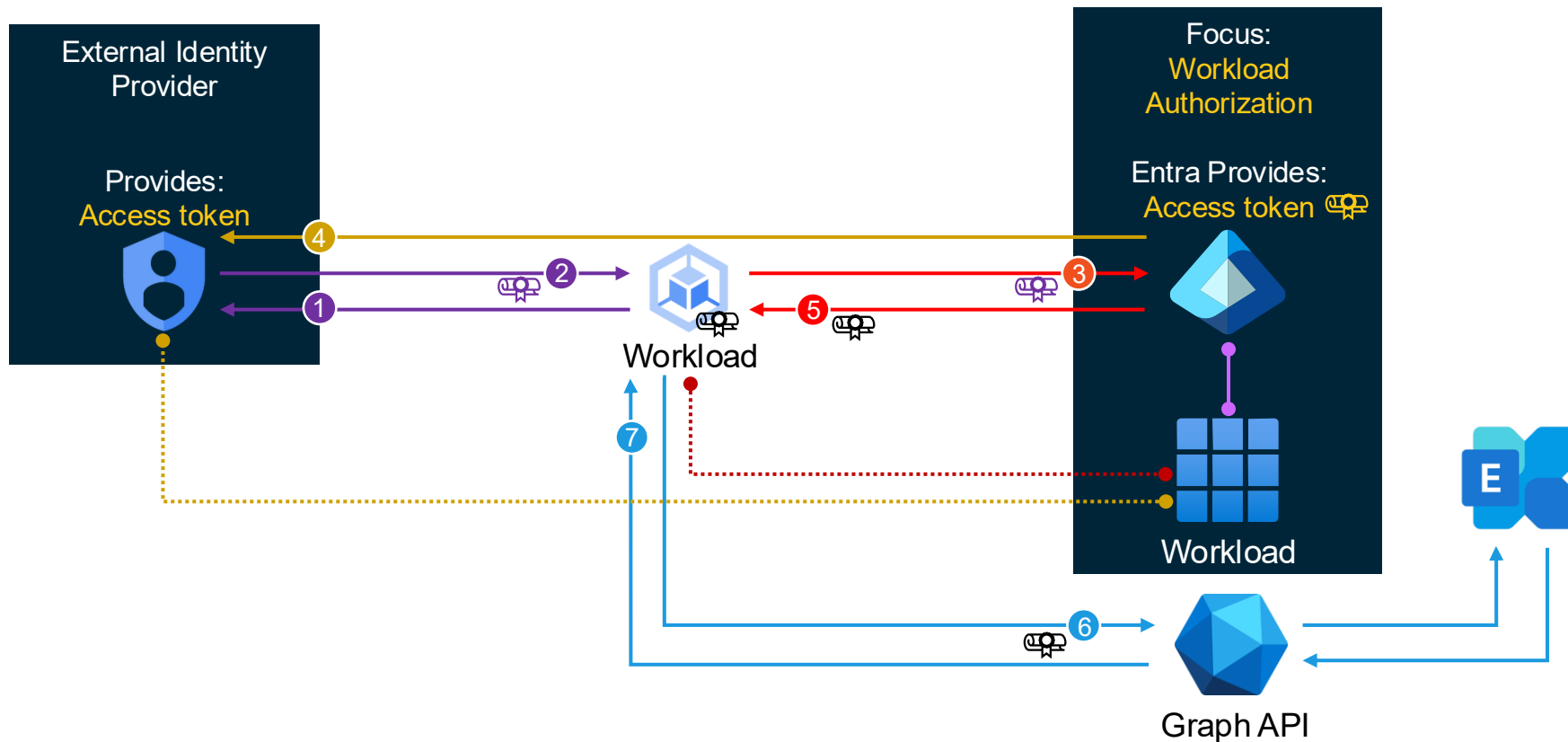


Good	Better	Best	Best
Secret *****	Certificate 	Managed Identity 	Federated Credential 
A password Has a lifetime Can be leaked	Asymmetric keypair Has a lifetime Can be leaked	For Azure workloads Removes credential handling Very difficult to leak	A trust relationship Removes credential handling Cannot be leaked

Credentials in multi-tenant scenarios

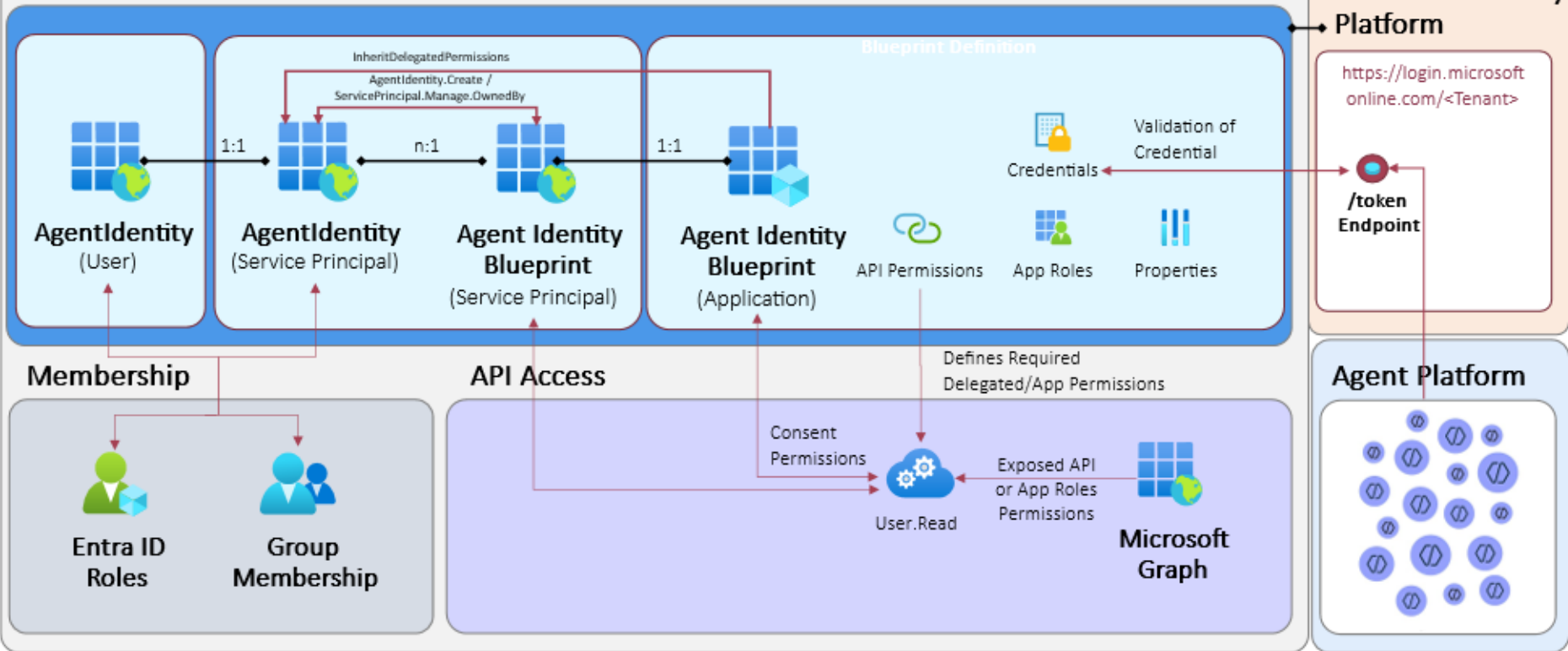


Federated credentials



Agent ID Overview

Microsoft Entra Agent ID Authorization

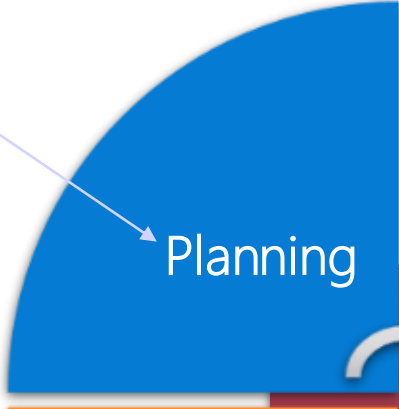




Policies and secure delegation for workload owners

Lifecycle phases of workload identities

- ☐ Requirements
- ☐ Type of Workload Identity
- ☐ Integration and Auth. Library
- ☐ Definition of Ownership



Planning

Critical default permissions

- By default, no limitation to require assignment to access Enterprise Apps

**Graph explorer (official site)** | Properties
Enterprise Application
Assignment required? ⓘ

Yes No

Assign users and groups to app-roles for your application here. App-roles are made available by the developer of the application by using the application registration.

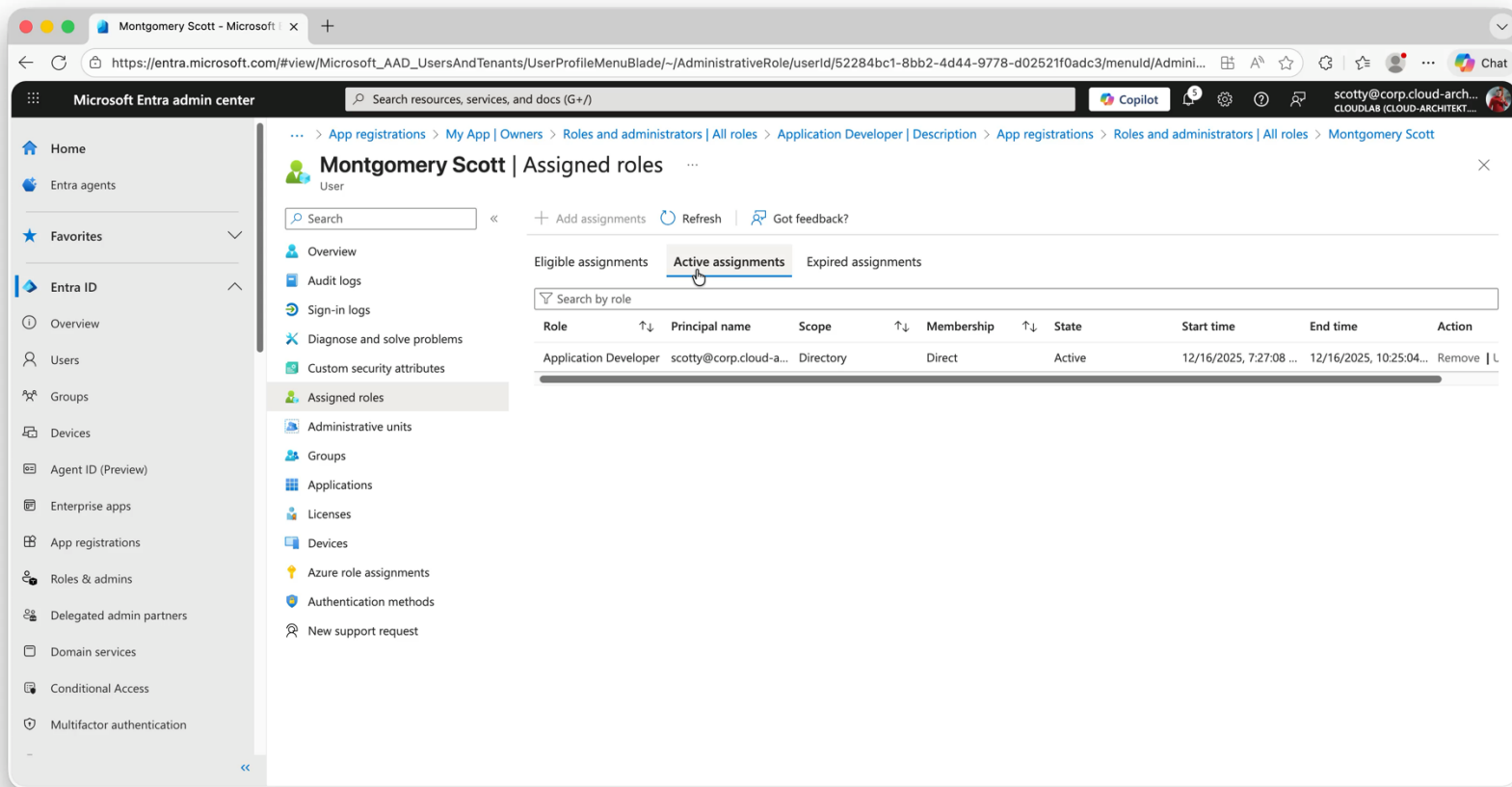
☐  dug_AAD.PrivilegedAccounts Group Default Access

- Default permission for (Member) user on Enterprise Apps (Service Principals)

App registrations
Users can register applications ⓘ
Yes No

**Application developer**
Description: Users in this role will continue to be able to register app registrations even if the Global Admin has turned off the tenant level switch for "Users can register apps".

Default assigned ownership by creation



The screenshot shows the Microsoft Entra admin center interface. The left sidebar contains navigation links: Home, Entra agents, Favorites, Entra ID (selected), Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, and Multifactor authentication. The main content area displays the 'Assigned roles' for the user 'Montgomery Scott'. The breadcrumb trail is: App registrations > My App > Owners > Roles and administrators | All roles > Application Developer | Description > App registrations > Roles and administrators | All roles > Montgomery Scott. The 'Assigned roles' section has tabs for 'Eligible assignments', 'Active assignments' (selected), and 'Expired assignments'. Below the tabs is a search bar 'Search by role'. A table lists the active assignments:

Role	Principal name	Scope	Membership	State	Start time	End time	Action
Application Developer	scotty@corp.cloud-a...	Directory	Direct	Active	12/16/2025, 7:27:08 ...	12/16/2025, 10:25:04 ...	Remove L

Custom roles for app registration

 **Application Creator without Owner** | Description ...

Privileged Identity Management | Microsoft Entra roles

»  Edit  Delete |  Got feedback?

Summary

Name: Application Creator without Owner

Description: Users in this role will be able to register app registrations without becoming owner.

Template ID: b6dda220-f45d-4348-8cdb-db0033cd795b

Role permissions

microsoft.directory/applications/create	Create all types of applications
microsoft.directory/servicePrincipals/create	Create service principals

Custom roles for app registration



Home > All roles >

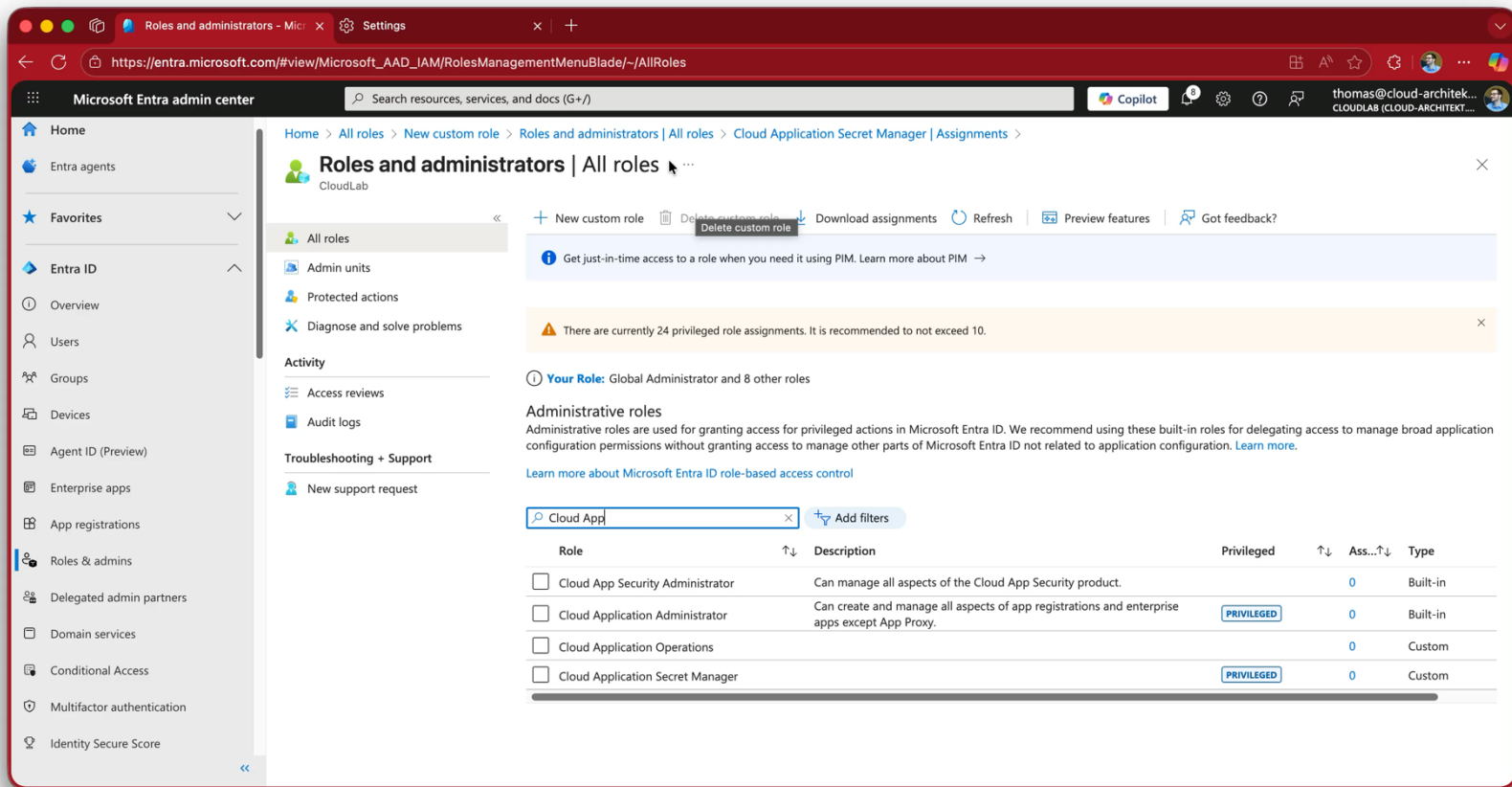
New custom role

All roles

Got feedback?

☐	microsoft.directory/applications.myOrganization/allProperties/read	Read all properties (including privileged properties) on single-directory applica...	
☐	microsoft.directory/applications.myOrganization/allProperties/update	Update all properties (including privileged properties) on single-directory appli...	PRIVILEGED
☐	microsoft.directory/applications.myOrganization/audience/update	Update audience on single-directory applications	
☐	microsoft.directory/applications.myOrganization/authentication/update	Update authentication on single-directory applications	
☐	microsoft.directory/applications.myOrganization/basic/update	Update basic properties on single-directory applications	
☐	microsoft.directory/applications.myOrganization/credentials/update	Update credentials on single-directory applications	PRIVILEGED
☐	microsoft.directory/applications.myOrganization/delete	Delete single-directory applications	
☐	microsoft.directory/applications.myOrganization/owners/read	Read owners on single-directory applications	
☐	microsoft.directory/applications.myOrganization/owners/update	Update owners on single-directory applications	
☐	microsoft.directory/applications.myOrganization/permissions/update	Update exposed permissions and required permissions on single-tenant applic...	
☐	microsoft.directory/applications.myOrganization/standard/read	Read basic properties on single-directory applications	
☐	microsoft.directory/applications/allProperties/read	Read all properties (including privileged properties) on all types of applications	
☐	microsoft.directory/applications/allProperties/update	Update all properties (including privileged properties) on all types of applicatio...	PRIVILEGED
☐	microsoft.directory/applications/applicationProxy/read	Read all application proxy properties	
☐	microsoft.directory/applications/applicationProxy/update	Update all application proxy properties	
☐	microsoft.directory/applications/applicationProxyAuthentication/update	Update authentication on all types of applications	

Add custom role for credential management with PIM



Microsoft Entra admin center

Home > All roles > New custom role > Roles and administrators | All roles > Cloud Application Secret Manager | Assignments

Roles and administrators | All roles

CloudLab

+ New custom role Delete custom role Download assignments Refresh Preview features Got feedback?

Get just-in-time access to a role when you need it using PIM. Learn more about PIM →

There are currently 24 privileged role assignments. It is recommended to not exceed 10.

Your Role: Global Administrator and 8 other roles

Administrative roles

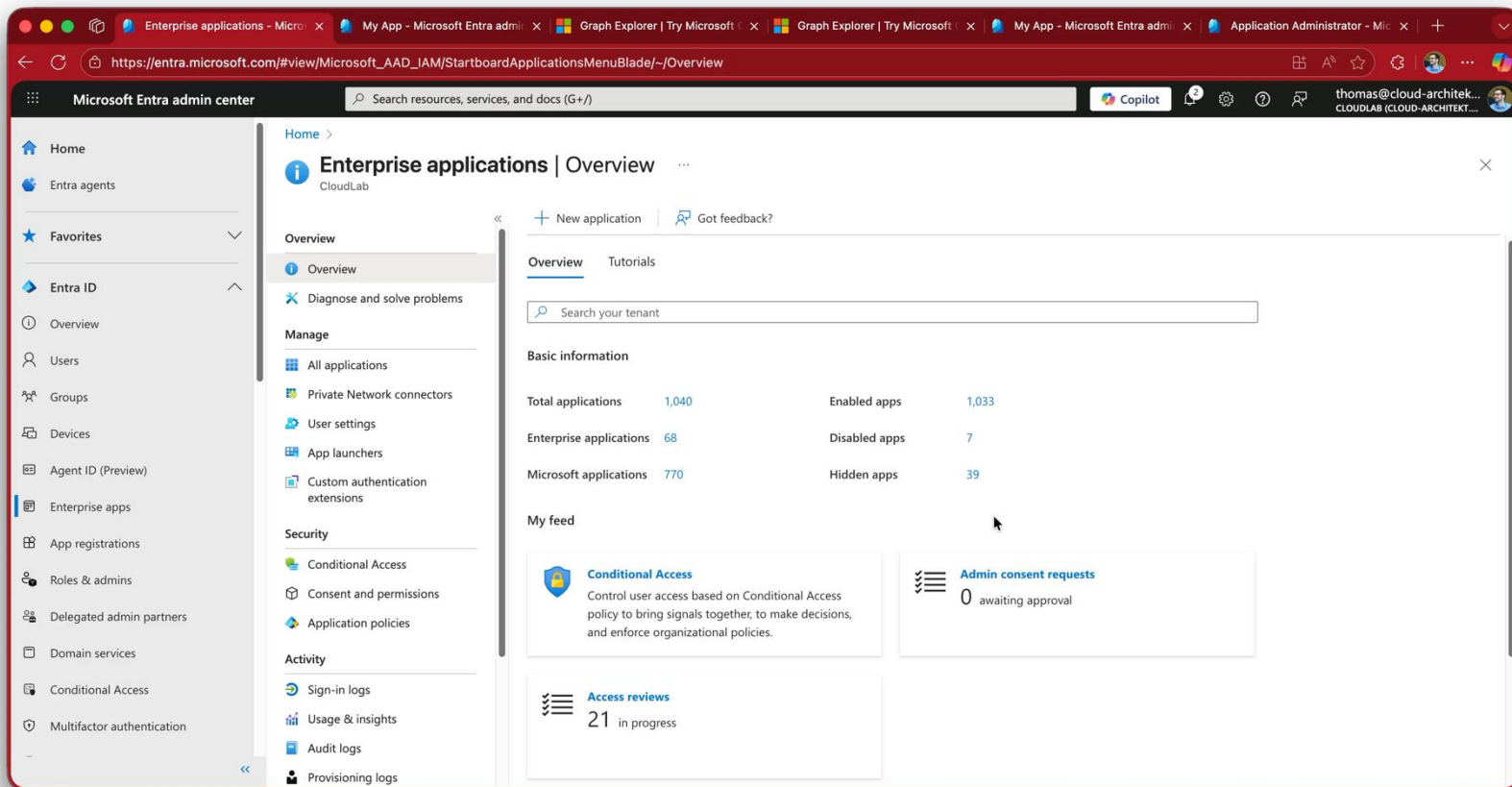
Administrative roles are used for granting access for privileged actions in Microsoft Entra ID. We recommend using these built-in roles for delegating access to manage broad application configuration permissions without granting access to manage other parts of Microsoft Entra ID not related to application configuration. [Learn more.](#)

[Learn more about Microsoft Entra ID role-based access control](#)

Cloud App Add filters

Role	Description	Privileged	Ass...	Type
☐ Cloud App Security Administrator	Can manage all aspects of the Cloud App Security product.		0	Built-in
☐ Cloud Application Administrator	Can create and manage all aspects of app registrations and enterprise apps except App Proxy.	PRIVILEGED	0	Built-in
☐ Cloud Application Operations			0	Custom
☐ Cloud Application Secret Manager		PRIVILEGED	0	Custom

Default tenant app management policy

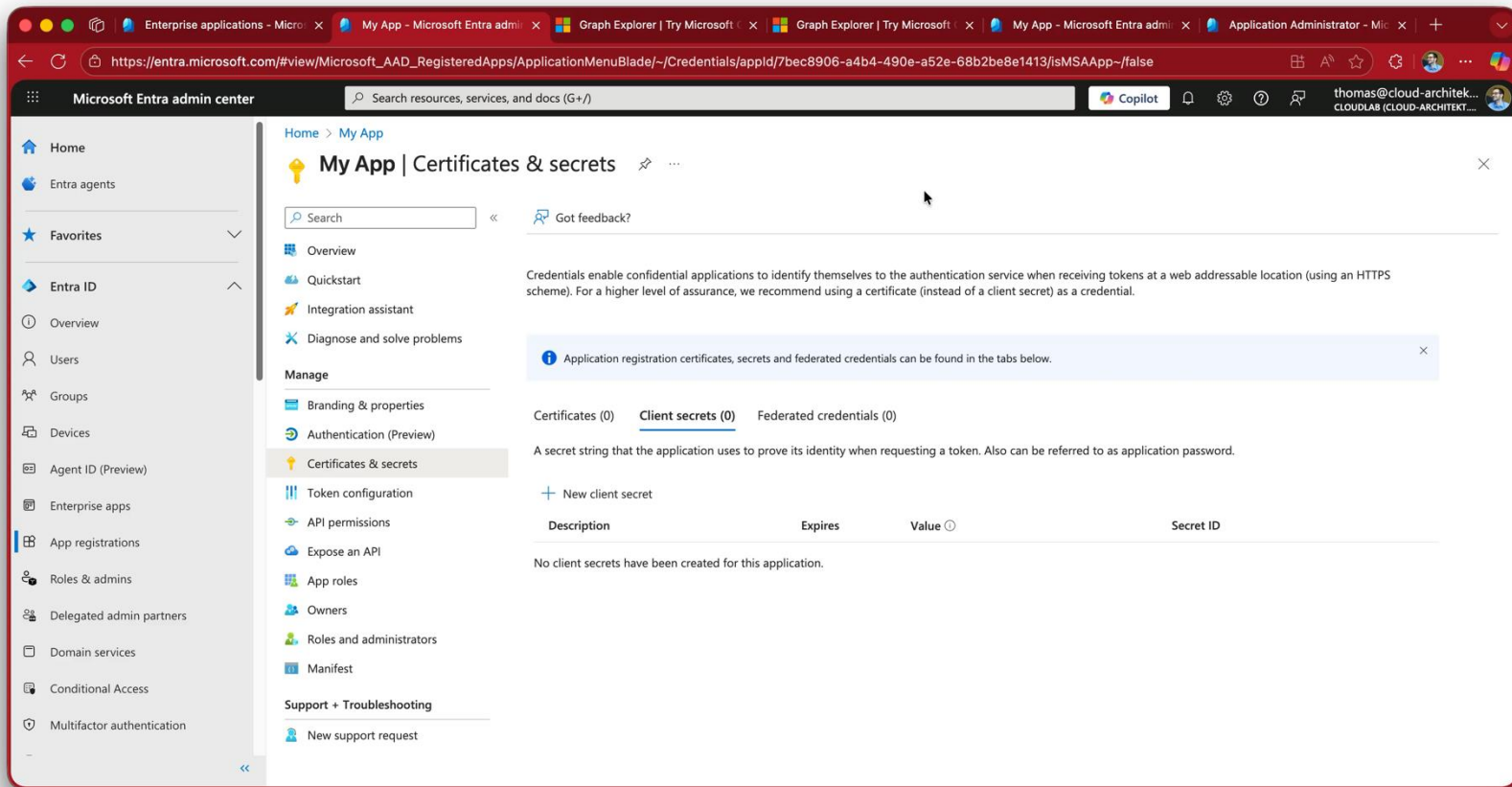


The screenshot displays the Microsoft Entra admin center interface. The left-hand navigation pane includes sections for Home, Entra agents, Favorites, Entra ID (with sub-items like Overview, Users, Groups, Devices, Agent ID, Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, and Multifactor authentication), and Provisioning logs. The main content area is titled 'Enterprise applications | Overview' and features a search bar and a 'New application' button. Below this, a 'Basic information' section provides a summary of applications:

Category	Count
Total applications	1,040
Enterprise applications	68
Microsoft applications	770
Enabled apps	1,033
Disabled apps	7
Hidden apps	39

The 'My feed' section on the right contains three items: 'Conditional Access' (Control user access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.), 'Admin consent requests' (0 awaiting approval), and 'Access reviews' (21 in progress).

Policies for service principal and applications



The screenshot shows the Microsoft Entra admin center interface. The left sidebar contains navigation links for Home, Entra agents, Favorites, Entra ID (Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, Multifactor authentication), and Support + Troubleshooting. The main content area is titled 'My App | Certificates & secrets'. It includes a search bar, a 'Got feedback?' link, and a list of options: Overview, Quickstart, Integration assistant, Diagnose and solve problems, Manage (Branding & properties, Authentication (Preview), Certificates & secrets, Token configuration, API permissions, Expose an API, App roles, Owners, Roles and administrators, Manifest), and Support + Troubleshooting (New support request). The 'Certificates & secrets' section is active, showing a description of credentials and a table for client secrets. A message states: 'Application registration certificates, secrets and federated credentials can be found in the tabs below.' The table has columns for Description, Expires, Value, and Secret ID. A note indicates that no client secrets have been created for this application.

Home > My App

My App | Certificates & secrets

Search

Got feedback?

Overview

Quickstart

Integration assistant

Diagnose and solve problems

Manage

Branding & properties

Authentication (Preview)

Certificates & secrets

Token configuration

API permissions

Expose an API

App roles

Owners

Roles and administrators

Manifest

Support + Troubleshooting

New support request

Credentials enable confidential applications to identify themselves to the authentication service when receiving tokens at a web addressable location (using an HTTPS scheme). For a higher level of assurance, we recommend using a certificate (instead of a client secret) as a credential.

Application registration certificates, secrets and federated credentials can be found in the tabs below.

Certificates (0) Client secrets (0) Federated credentials (0)

A secret string that the application uses to prove its identity when requesting a token. Also can be referred to as application password.

+ New client secret

Description	Expires	Value	Secret ID
No client secrets have been created for this application.			

Azure policy for Managed Identity Federated Credentials



Microsoft Azure

Search resources, services, and docs (G+/)

Dashboard > Policy | Assignments >

[Preview]: Managed Identity Federated Credentials should be of approved types from approved federation sources

Initiative Assignment

Definition version	: 1.0.*-preview	Excluded scopes	: --
Description	: --	Definition type	: Initiative
Assignment ID	: /providers/microsoft.management/managementgroups/lab/providers/microsoft.autho...	Policy enforcement	: Default
Assigned by	: --		

Parameters (9) Resource selectors (0) Overrides (0) Exemptions (0) Remediation (0) Deployed resources Managed Identity

Search by parameter name All types

Edit columns

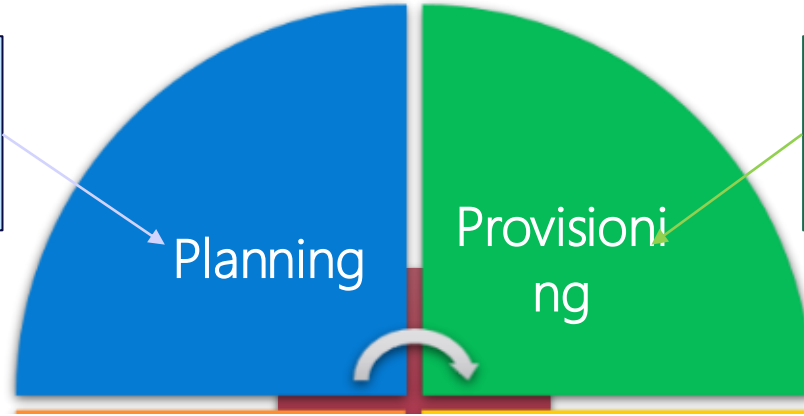
Parameter ID	Parameter name	Parameter value	Policy assignment parameter reference type
allowFederatedCredentials	Allow Federated Credentials	true	User defined parameter
allowGitHub	Allow GitHub	true	User defined parameter
allowedGitHubRepoOwners	Allowed GitHub Repo Owners	["cloud-architekt"]	User defined parameter
effect	Effect	"Audit"	Default value
allowedIssuerExceptions	Allowed Issuer Exceptions		Default value
allowedGitHubRepoExceptions	Allowed GitHub Repo Exceptions		Default value
allowedAKSClusterExceptions	Allowed AKS Cluster Exceptions		Default value
allowedAKSLocations	Allowed AKS cluster locations		Default value
allowedAKSTenants	Allowed AKS cluster tenants		Default value

Give feedback

Lifecycle phases of workload identities

- ☐ Requirements
- ☐ Type of Workload Identity
- ☐ Integration and Auth. Library
- ☐ Definition of Ownership

Planning



Provisioning

- ☐ Create workload identity
- ☐ Assignment of Permissions
- ☐ Delegation and Classification
- ☐ Issuing credentials (if needed)

Management API permissions in Identity Governance

Microsoft Entra admin center Search resources, services, and docs (G+/)

Home > Identity Governance | Access packages >

New access package

Who can get access *

- ☒ For users, service principals, and agent identities in your directory
Allow users, groups, service principals, and agent identities in your directory to get access to this access package
- ☐ For users not in your directory
Allow users in connected organizations (other directories and domains) to get access to this access package
- ☐ None (administrator direct assignments only)
Allow administrators to directly assign specific users to this access package. No subjects can get access without being explicitly assigned by administrator.

Select specific scope

- ☐ Specific users and groups
- ☐ All members (excluding guests)
- ☐ All users (including guests)
- ☒ All service principals (preview)
- ☐ All agents (preview)

Who can request access

Who can request access *

- ☒ Self
- ☒ Admin
Admin can't be turned off because admins will always be able to assign users to an access package.
- ☐ Manager
- ☒ Service Principal Owner

Approval

Review + create Previous Next: Requestor Information >

Management API permissions in Identity Governance

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Copilot

thomas@cloud-architek...
CLOUDLAB (CLOUD-ARCHITEKT...

Home > Identity Governance | Access packages >

New access package

* Basics **Resource roles** * Requests Requestor information * Lifecycle Custom extensions Review + create

Add different resources to this access package. Specify the permissions associated with each resource by selecting a role from the drop-down list. [Learn more](#)

+ Groups and Teams + Applications + SharePoint sites + Microsoft Entra role (Preview) + API Permissions (Preview)

Resource	Type	Sub Type	Role Type	Role *
Microsoft Graph	OAuthApplication	API	Application	User.ReadBasic.All
Microsoft Graph	OAuthApplication	API	Delegated	openid
Microsoft Graph	OAuthApplication	API	Delegated	profile

Review + create Previous Next: Requests >



HYBRID
IDENTITY
PROTECTION
conf26

Real world abuses against workload identities

Exposed credentials

- Repots can be scanned for publicly exposed credentials
- The focus tends to be on secret scanning, but any credential such as a private key can also be abused
- Detection of credentials is not the same as prevention

×

 [Secret scanning](#) found a Azure Active Directory Application Secret secret on [line 4](#).

Allowing this secret risks exposure. Instead, consider [removing the secret from your commit and commit history](#).

Exposing this secret can allow someone to:

- Verify the identity of this Azure Active Directory Application Secret secret
- Know which resources this secret can access
- Act on behalf of the secret's owner
- Push this secret to this repository without being blocked

☐ It's used in tests
The secret poses no risk. If anyone finds it, they cannot do any damage or gain access to sensitive information.

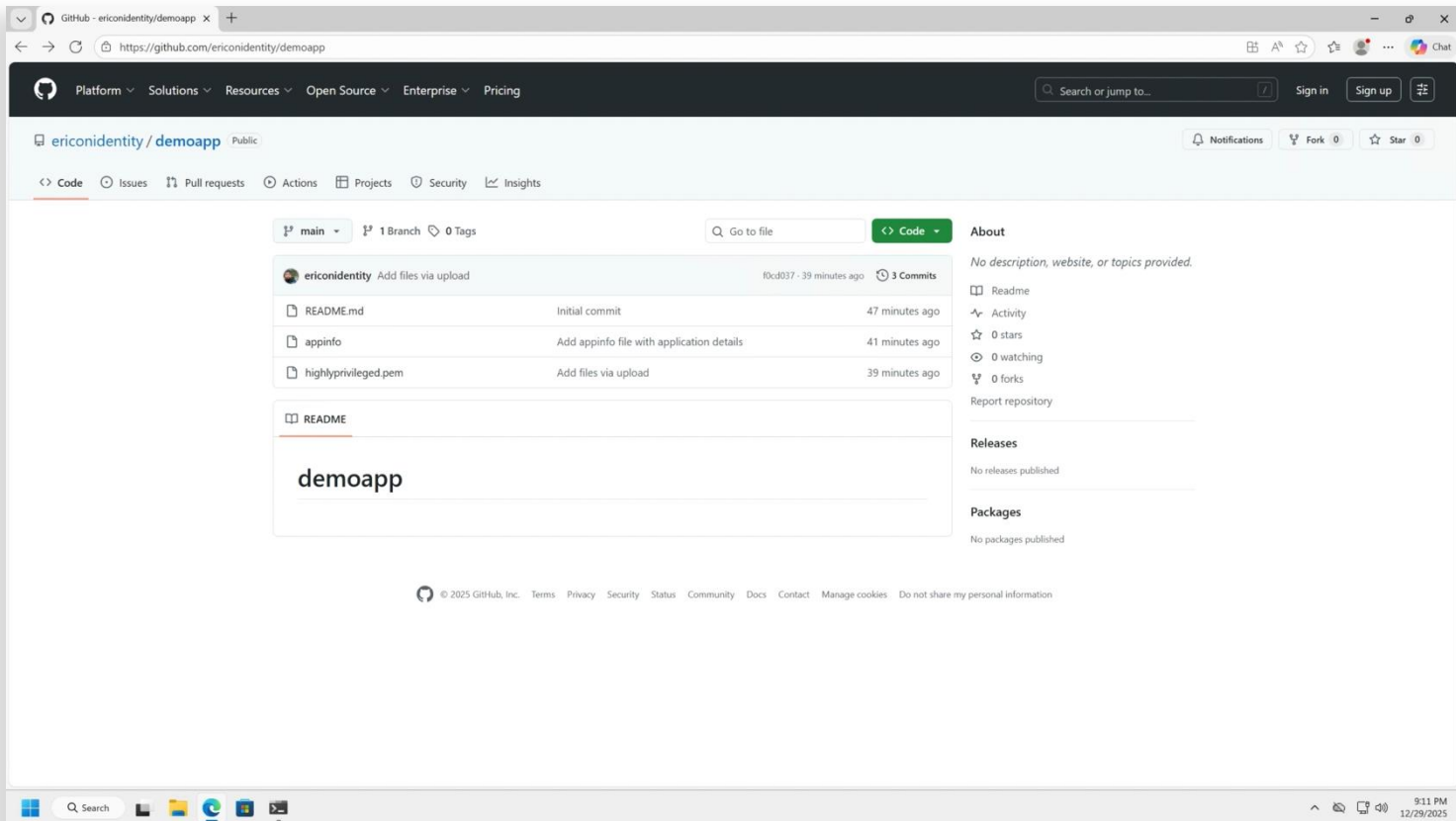
☐ It's a false positive
The detected string is not a secret.

☐ I'll fix it later
The secret is real, I **understand the risk**, and I will need to revoke it. This will open a security alert and notify admins of this repository.

Cancel

Allow Secret

Abusing publicly exposed credentials



The screenshot shows a web browser displaying the GitHub repository page for `ericonidentity/demoapp`. The repository is public and has 0 forks and 0 stars. The main branch is `main`. The repository contains three files: `README.md`, `appinfo`, and `highlyprivileged.pem`. The `README.md` file is selected, showing the text `demoapp`. The repository has 3 commits, with the most recent commit being `f0cd037` from 39 minutes ago. The repository is described as "Add files via upload". The repository is located at `https://github.com/ericonidentity/demoapp`. The browser's address bar shows the URL. The browser's taskbar at the bottom shows the Windows logo, a search bar, and several application icons. The system clock in the bottom right corner shows the time as 9:11 PM on 12/29/2023.

GitHub - ericonidentity/demoapp

Platform Solutions Resources Open Source Enterprise Pricing

Search or jump to... Sign in Sign up

ericonidentity / demoapp Public

Notifications Fork 0 Star 0

<> Code Issues Pull requests Actions Projects Security Insights

main 1 Branch 0 Tags

Go to file Code

ericonidentity Add files via upload f0cd037 - 39 minutes ago 3 Commits

README.md	Initial commit	47 minutes ago
appinfo	Add appinfo file with application details	41 minutes ago
highlyprivileged.pem	Add files via upload	39 minutes ago

README

demoapp

About

No description, website, or topics provided.

- Readme
- Activity
- 0 stars
- 0 watching
- 0 forks

Report repository

Releases

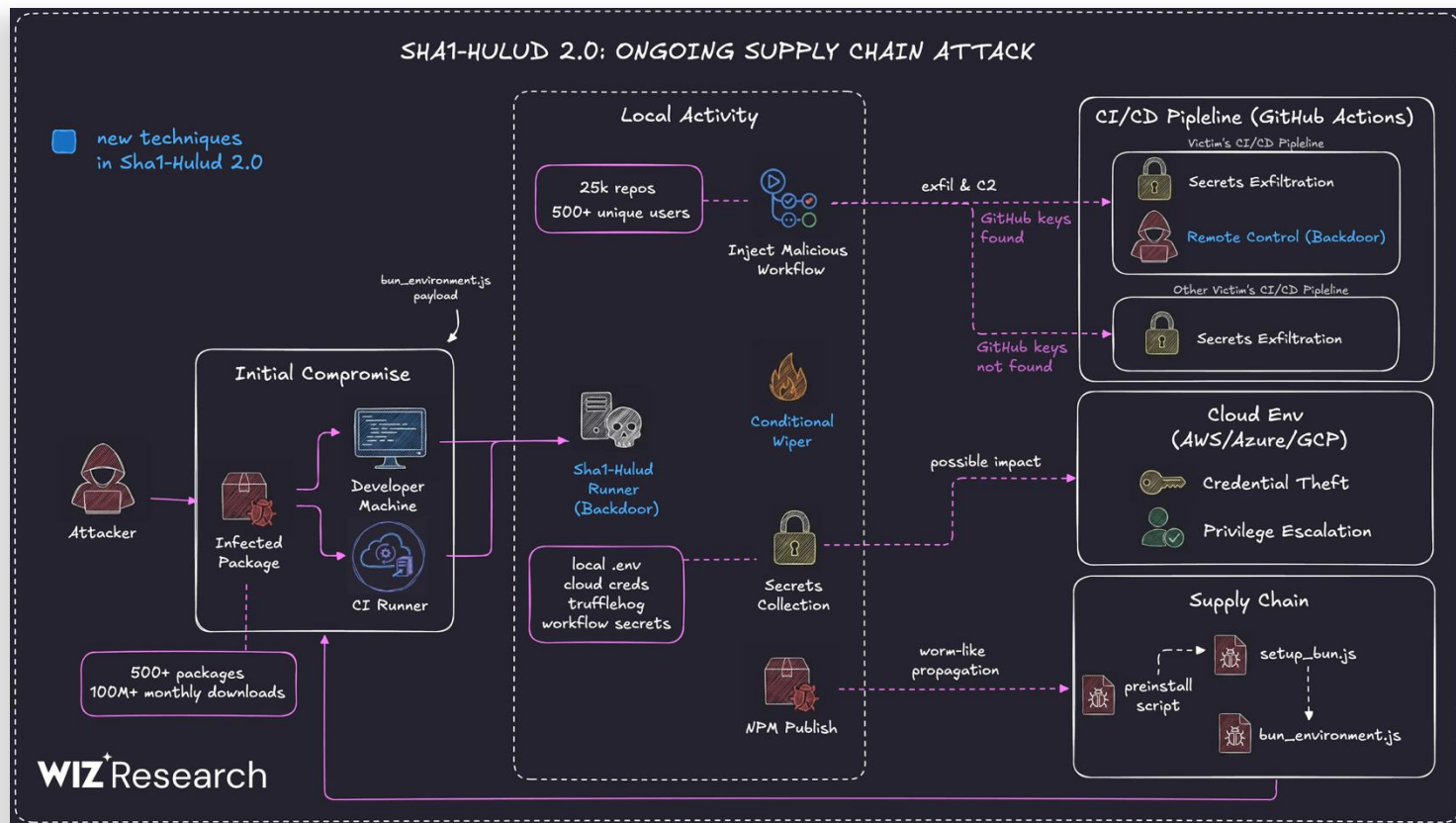
No releases published

Packages

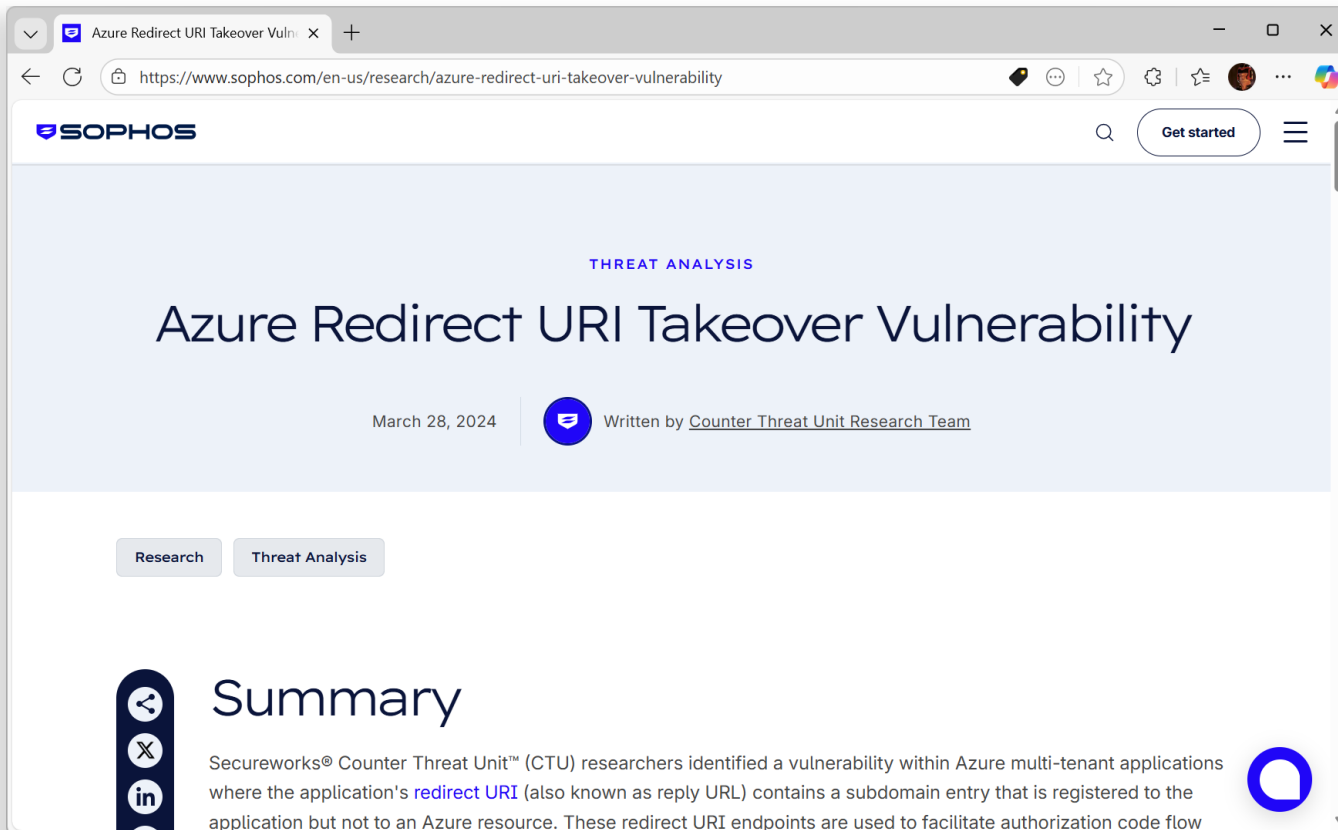
No packages published

© 2025 GitHub, Inc. Terms Privacy Security Status Community Docs Contact Manage cookies Do not share my personal information

Credential theft in supply chain attacks



Abusing redirect URIs



A screenshot of a web browser displaying a research article from Sophos. The browser's address bar shows the URL <https://www.sophos.com/en-us/research/azure-redirect-uri-takeover-vulnerability>. The page header features the Sophos logo and a 'Get started' button. The main content area has a light blue background with the title 'Azure Redirect URI Takeover Vulnerability' in large, dark blue font. Above the title, the words 'THREAT ANALYSIS' are written in smaller, blue, all-caps font. Below the title, the date 'March 28, 2024' is displayed next to a circular profile icon, followed by the text 'Written by [Counter Threat Unit Research Team](#)'. Below this, there are two buttons: 'Research' and 'Threat Analysis', with the latter being highlighted. The 'Summary' section begins with a vertical stack of three circular icons (a left arrow, a crossed-out circle, and the LinkedIn logo) and the word 'Summary' in large, dark blue font. The summary text states: 'Secureworks® Counter Threat Unit™ (CTU) researchers identified a vulnerability within Azure multi-tenant applications where the application's [redirect URI](#) (also known as reply URL) contains a subdomain entry that is registered to the application but not to an Azure resource. These redirect URI endpoints are used to facilitate authorization code flow'. A blue circular icon is visible in the bottom right corner of the page.

Azure Redirect URI Takeover Vulnerability

THREAT ANALYSIS

March 28, 2024 | Written by [Counter Threat Unit Research Team](#)

Research Threat Analysis

Summary

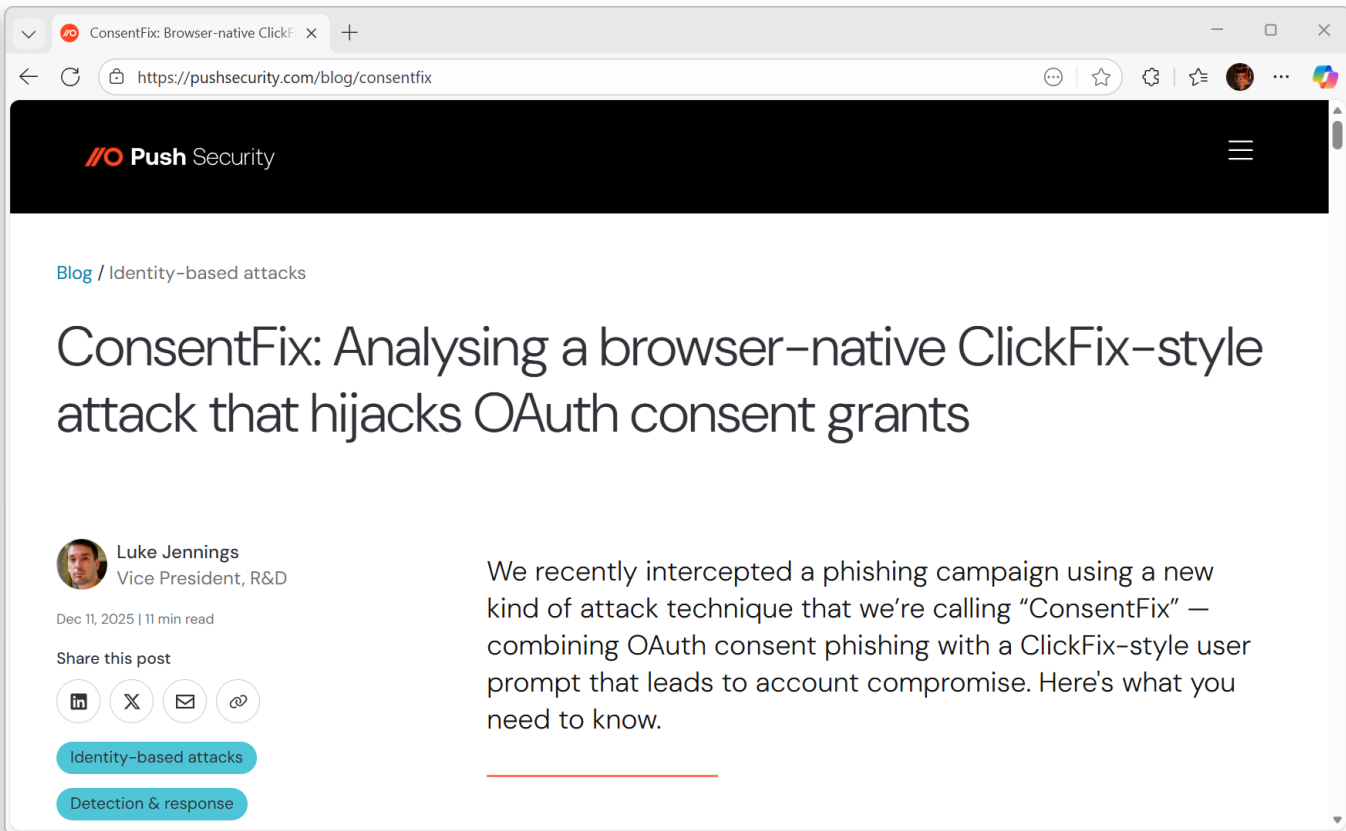
Secureworks® Counter Threat Unit™ (CTU) researchers identified a vulnerability within Azure multi-tenant applications where the application's [redirect URI](#) (also known as reply URL) contains a subdomain entry that is registered to the application but not to an Azure resource. These redirect URI endpoints are used to facilitate authorization code flow

Abusing redirect URIs



- Can be used to abuse 3rd party and Microsoft applications
- Attackers leverage localhost or dangling hostnames on service principals
- Allows an attacker to obtain an authorization code
- Attacker redeems the authorization code for an access token

ConsentFix redirect URI abuse



The screenshot shows a web browser window with the address bar displaying `https://pushsecurity.com/blog/consentfix`. The page header features the Push Security logo and a hamburger menu. The main content area has a breadcrumb trail "Blog / Identity-based attacks" and a large title "ConsentFix: Analysing a browser-native ClickFix-style attack that hijacks OAuth consent grants". Below the title, the author is identified as Luke Jennings, Vice President, R&D, with a profile picture. The post date is "Dec 11, 2025 | 11 min read". There are social sharing icons for LinkedIn, X, Email, and a generic share icon. Two teal tags are present: "Identity-based attacks" and "Detection & response". The main text of the post begins with "We recently intercepted a phishing campaign using a new kind of attack technique that we're calling 'ConsentFix' — combining OAuth consent phishing with a ClickFix-style user prompt that leads to account compromise. Here's what you need to know."

ConsentFix: Browser-native ClickFix-style attack

Push Security

Blog / Identity-based attacks

ConsentFix: Analysing a browser-native ClickFix-style attack that hijacks OAuth consent grants

 **Luke Jennings**
Vice President, R&D

Dec 11, 2025 | 11 min read

Share this post

Identity-based attacks

Detection & response

We recently intercepted a phishing campaign using a new kind of attack technique that we're calling "ConsentFix" — combining OAuth consent phishing with a ClickFix-style user prompt that leads to account compromise. Here's what you need to know.

ConsentFix redirect URI abuse

- Abuses privileged Microsoft applications
- Is an evolution of ClickFix attacks
- Victim is social engineered to provide the authorization code URL to the attacker

Verify you are human by completing the action below.

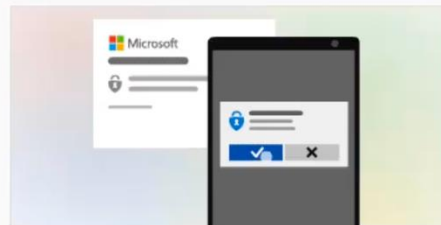
victim@company.com

Paste URL to allow access

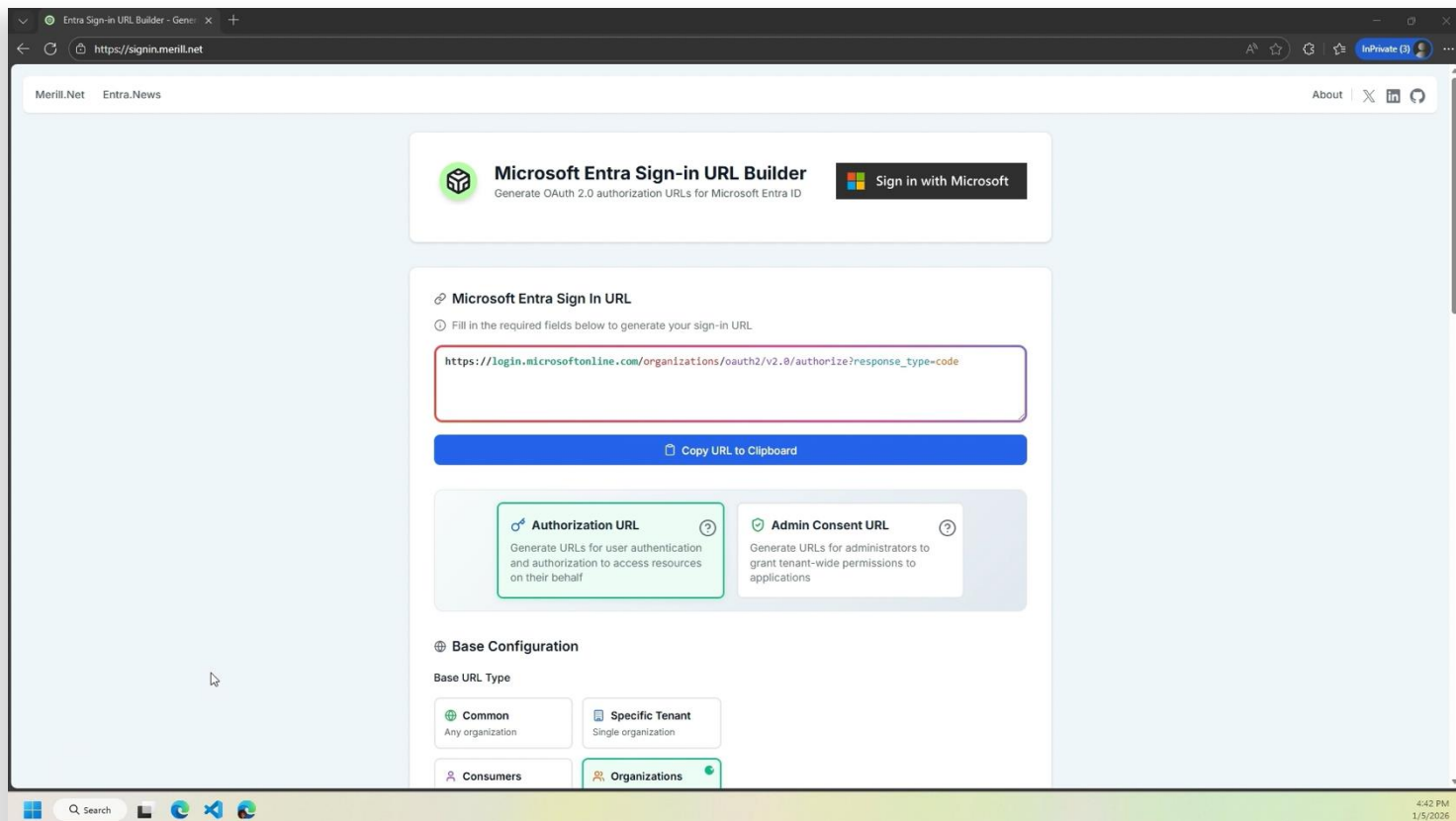
Sign in to your Microsoft account to verify your identity and after successful authentication, copy the URL received and paste it below.

http://

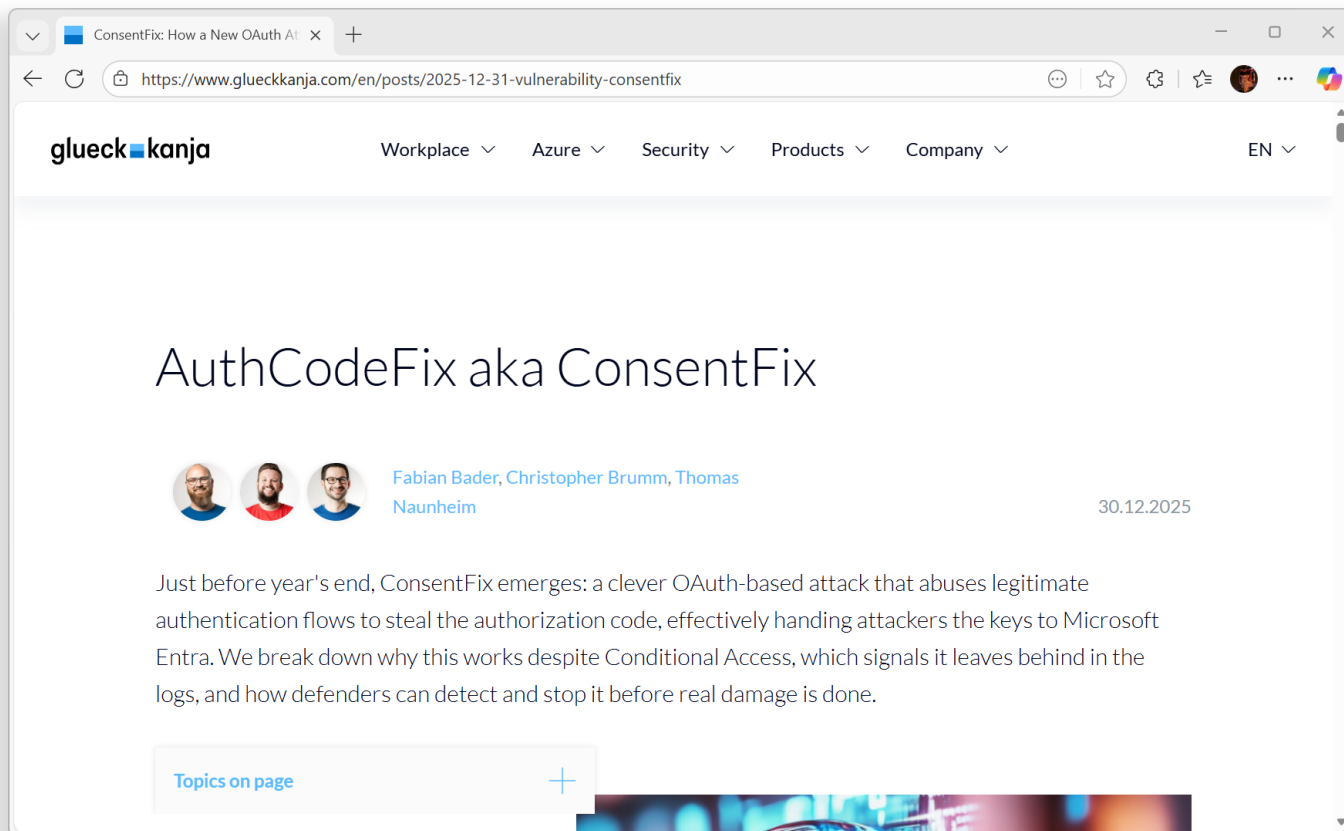
Sign in



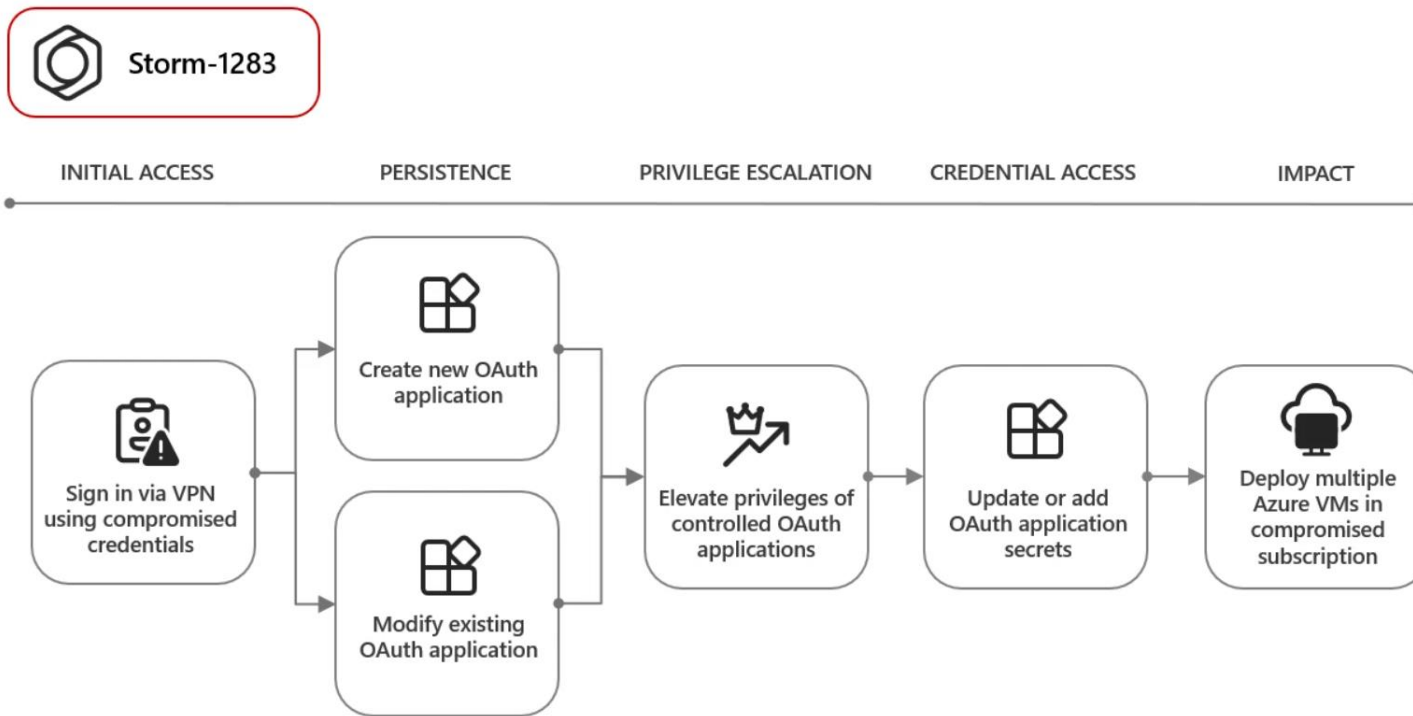
ConsentFix redirect URI abuse



ConsentFix redirect URI abuse



Attackers 🥰 service principals



Source: [Threat actors misuse OAuth applications to automate financially driven attacks](#)

Lifecycle phases of workload identities

- ☐ Requirements
- ☐ Type of Workload Identity
- ☐ Integration and Auth. Library
- ☐ Definition of Ownership

Planning

Provisioning

- ☐ Create workload identity
- ☐ Assignment of Permissions
- ☐ Delegation and Classification
- ☐ Issuing credentials (if needed)

Monitor and maintaining

- ☐ Activity and used permissions
- ☐ Suspicious sign-in or changes
- ☐ Delegations and Ownership
- ☐ Change/renewal credentials

Nation-state attack by Midnight Blizzard



Malicious use of OAuth applications

Threat actors like Midnight Blizzard compromise user accounts to create, modify, and grant high permissions to OAuth applications that they can misuse to hide malicious activity. The misuse of OAuth also enables threat actors to maintain access to applications, even if they lose access to the initially compromised account. Midnight Blizzard leveraged their initial access to identify and compromise a **legacy test OAuth application that had elevated access to the Microsoft corporate environment**. The actor created additional malicious OAuth applications. They created a new user account to grant consent in the Microsoft corporate environment to the actor controlled malicious OAuth applications. The threat actor then used the legacy test OAuth application to grant them the Office 365 Exchange Online ***full_access_as_app*** role, which allows access to mailboxes.



HYBRID
IDENTITY
PROTECTION
conf26

Security posture and XDR threat detection

Inventory and insights using WorkloadIdentityInfoXDR



Advanced hunting - Microsoft Defender

https://security.microsoft.com/v2/advanced-hunting?tid=36955ea9-c98e-4749-b603-ffef652dd90

Microsoft Defender

Advanced hunting

Selected workspace: lab-la-4d3e5b65-8a52-4b2f-b5cd-1670c700136b

Help resources Query resources report Schema reference Page preferences

New query* | New query* | + |

Run query | Last 30 days | Save | Share link | Create summary rule | Create detection rule

Query

1 WorkloadIdentityInfoXdr

Getting started Results Query history

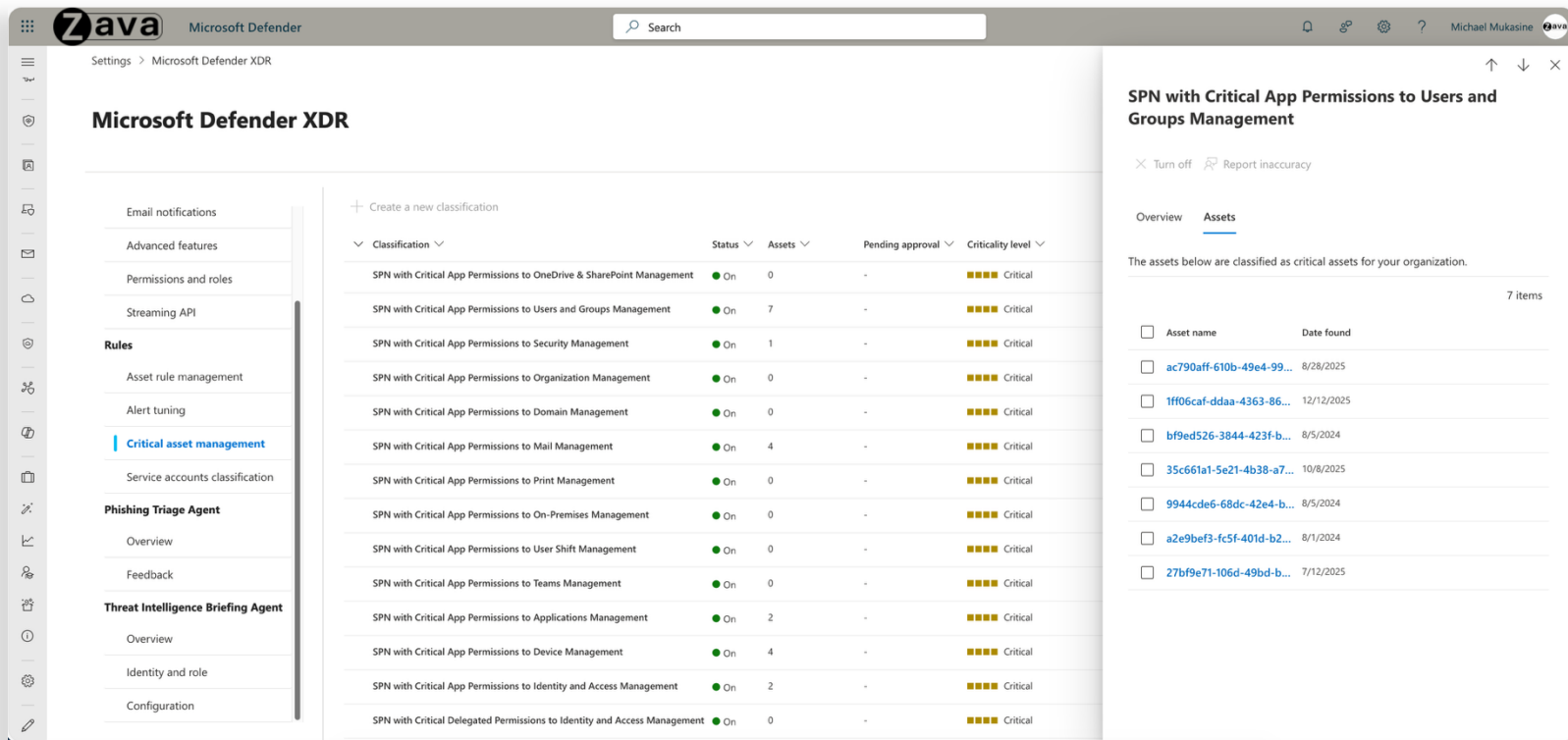
Export Link to incident Take actions Show empty columns 1 of 54 selected Search 00:11.906 Low Chart type Full screen

Filters: Add filter

	ServicePrincipalName	ServicePrincipalId	OAuthAppId	CriticalityLevel	AddedOnTime	LastModifiedTime	AppStatus	VerifiedPublisher
☒	> aadexporter-sp	ad4f7ea9-521d-422c-a3...	20f7a103-e7eb-49cf-9cf...		May 13, 2021 1:22:38 PM		Enabled	{}
☐	> aadops-pull-sp	01b83e5e-eca2-40cc-92...	8d49d8d1-c448-4996-a...		Jan 18, 2021 2:48:11 PM		Enabled	{}
☐	> ASPADev	5892a25b-509f-4f3e-acc...	1309b33f-ecf2-4786-aa1...		Jul 1, 2025 11:24:59 AM		Enabled	{}
☐	> AzADServicePrinci...	df91eecc-9fc9-49d3-aaa...	e7843299-6dab-4683-8...		Apr 9, 2022 10:56:57 PM		Enabled	{}
☐	> AzGovViz	4434a136-a704-4306-8...	34f7258a-81a0-4f72-bbf...		Jan 11, 2022 9:21:48 AM	Jun 12, 2023 11:52:48 AM	DisabledByUser	{}
☐	> azops-pull-sp	deea7af6-3531-41a0-b8...	e96c653b-9ea0-4bcf-b0...		Oct 18, 2020 9:38:28 AM		Enabled	{}
☐	> AzSentinel-Playbo...	1c334d68-ce72-4efa-a0...	5d6db40a-65a4-4fb2-a...		Sep 10, 2021 9:04:48 AM		Enabled	{}
☐	> Azure AD Terraform	86c4ff0b-b24d-431f-b5...	acc97b04-e430-4541-99...	1	Nov 21, 2022 7:40:01 AM		Enabled	{}
☐	> Azure Logic Apps ...	3037993f-35f8-46d2-be...	b2a54184-d0c5-4c6a-af...		Mar 26, 2021 12:18:05 PM		Enabled	{}

Detection Query: Cloud-Architekt/AzureSentinel - WorkloadIdentityInfoXdr

Workload identities in critical asset management



The screenshot displays the Zava Microsoft Defender XDR interface. The left sidebar contains navigation options: Email notifications, Advanced features, Permissions and roles, Streaming API, Rules, Asset rule management, Alert tuning, Critical asset management (highlighted), Service accounts classification, Phishing Triage Agent, Threat Intelligence Briefing Agent, Overview, Identity and role, and Configuration.

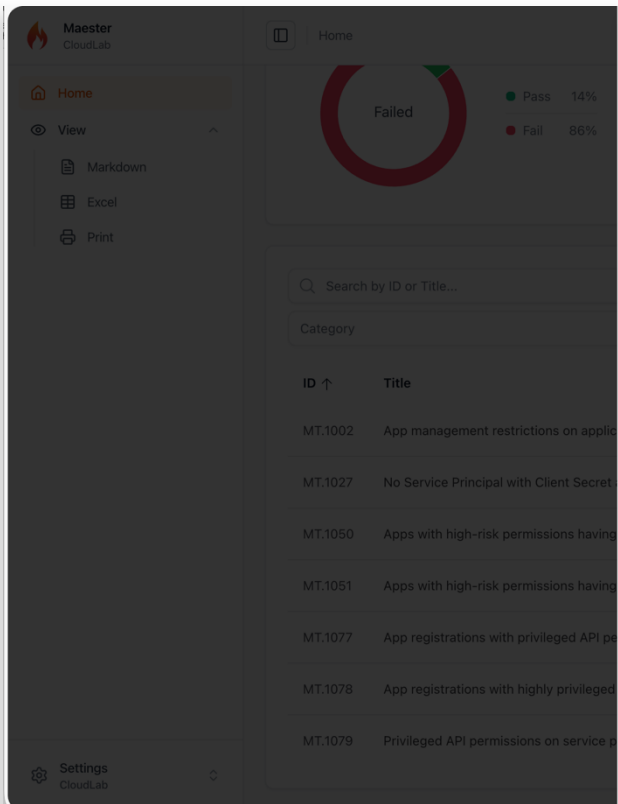
The main content area is titled "Microsoft Defender XDR" and shows a table of workload identities classified as critical assets. The table has columns for Classification, Status, Assets, Pending approval, and Criticality level. The "Criticality level" column shows a green dot and the word "Critical".

Classification	Status	Assets	Pending approval	Criticality level
SPN with Critical App Permissions to OneDrive & SharePoint Management	On	0	-	Critical
SPN with Critical App Permissions to Users and Groups Management	On	7	-	Critical
SPN with Critical App Permissions to Security Management	On	1	-	Critical
SPN with Critical App Permissions to Organization Management	On	0	-	Critical
SPN with Critical App Permissions to Domain Management	On	0	-	Critical
SPN with Critical App Permissions to Mail Management	On	4	-	Critical
SPN with Critical App Permissions to Print Management	On	0	-	Critical
SPN with Critical App Permissions to On-Premises Management	On	0	-	Critical
SPN with Critical App Permissions to User Shift Management	On	0	-	Critical
SPN with Critical App Permissions to Teams Management	On	0	-	Critical
SPN with Critical App Permissions to Applications Management	On	2	-	Critical
SPN with Critical App Permissions to Device Management	On	4	-	Critical
SPN with Critical App Permissions to Identity and Access Management	On	2	-	Critical
SPN with Critical Delegated Permissions to Identity and Access Management	On	0	-	Critical

The right sidebar shows the "SPN with Critical App Permissions to Users and Groups Management" details. It includes a "Turn off" button and a "Report inaccuracy" button. The "Assets" tab is selected, showing a list of 7 items. The list includes columns for Asset name and Date found.

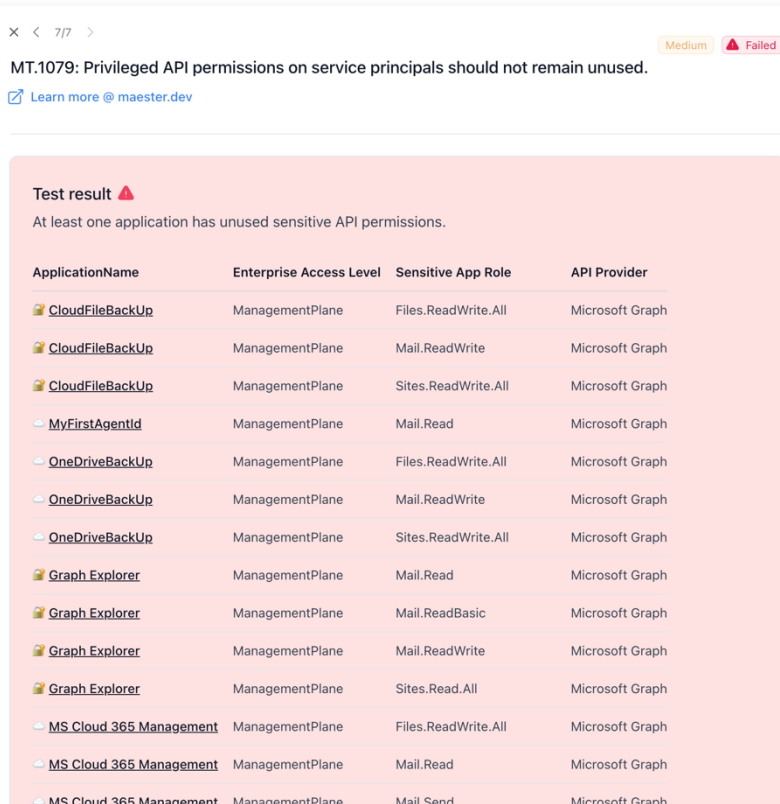
Asset name	Date found
ac790aff-610b-49e4-99...	8/28/2025
1ff06caf-ddaa-4363-86...	12/12/2025
b19ed526-3844-423f-b...	8/5/2024
35c661a1-5e21-4b38-a7...	10/8/2025
9944cde6-68dc-42e4-b...	8/5/2024
a2e9bef3-fc5f-401d-b2...	8/1/2024
27bf9e71-106d-49bd-b...	7/12/2025

Application and service principal checks in Maester



The Maester CloudLab interface shows a sidebar with navigation options: Home, View, Markdown, Excel, and Print. The main content area displays a large circular progress indicator with a red segment indicating a 'Failed' status. Below the indicator, a search bar and a table of results are visible. The table has columns for ID and Title. The results show a list of checks, with the last one, MT.1079, highlighted in red and labeled 'Failed'.

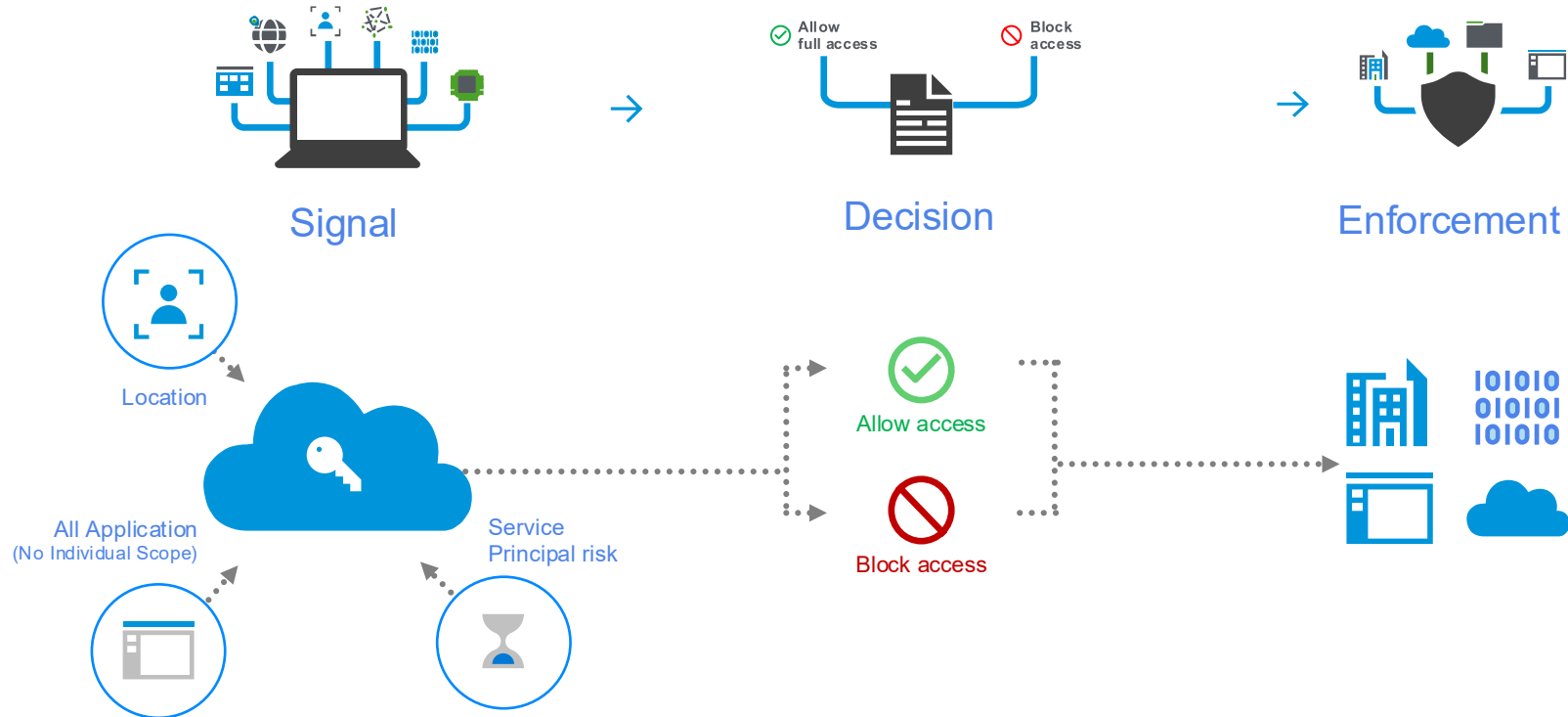
ID	Title
MT.1002	App management restrictions on applic
MT.1027	No Service Principal with Client Secret
MT.1050	Apps with high-risk permissions having
MT.1051	Apps with high-risk permissions having
MT.1077	App registrations with privileged API pe
MT.1078	App registrations with highly privileged
MT.1079	Privileged API permissions on service p



The detailed test result for MT.1079 shows a 'Failed' status with a 'Medium' severity. The message states: 'At least one application has unused sensitive API permissions.' Below the message is a table listing the applications and their permissions.

ApplicationName	Enterprise Access Level	Sensitive App Role	API Provider
CloudFileBackUp	ManagementPlane	Files.ReadWrite.All	Microsoft Graph
CloudFileBackUp	ManagementPlane	Mail.ReadWrite	Microsoft Graph
CloudFileBackUp	ManagementPlane	Sites.ReadWrite.All	Microsoft Graph
MyFirstAgentId	ManagementPlane	Mail.Read	Microsoft Graph
OneDriveBackUp	ManagementPlane	Files.ReadWrite.All	Microsoft Graph
OneDriveBackUp	ManagementPlane	Mail.ReadWrite	Microsoft Graph
OneDriveBackUp	ManagementPlane	Sites.ReadWrite.All	Microsoft Graph
Graph Explorer	ManagementPlane	Mail.Read	Microsoft Graph
Graph Explorer	ManagementPlane	Mail.ReadBasic	Microsoft Graph
Graph Explorer	ManagementPlane	Mail.ReadWrite	Microsoft Graph
Graph Explorer	ManagementPlane	Sites.Read.All	Microsoft Graph
MS Cloud 365 Management	ManagementPlane	Files.ReadWrite.All	Microsoft Graph
MS Cloud 365 Management	ManagementPlane	Mail.Read	Microsoft Graph
MS Cloud 365 Management	ManagementPlane	Mail.Send	Microsoft Graph

Conditional access for workload identities



Conditional access for workload identities

The screenshot shows the Microsoft Entra admin center interface. The left sidebar contains navigation links for Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, Multifactor authentication, Identity Secure Score, Authentication methods, Account recovery (Preview), Password reset, Custom security attributes, and Certificate authorities. The main content area is titled "Conditional Access | Policies" and shows a summary of policies. It includes three cards: "Conditional Access Optimization Agent" with 2 policies created and 0 suggestions, "Microsoft-managed policies" with 0 policies created, and "User created policies" with 69 policies created. Below these cards is a search bar with the filter "Workloads" applied, showing 2 out of 71 policies found. The table below lists the policies:

Policy name	Created by
401 - ALL - Workloads - Self Hosted Agent Pipelines: Block access from untrusted network locations	USER
402 - ALL - Workloads - High-privileged Workload Identity: Block access For When high workload identity risk is detected	USER

Workload identities premium?

Feature	Free (Entra ID License)	Premium (\$3/Month/Service Principal)
Authentication, Authorization, Sign-in and Audit Logs	Yes	Yes
Conditional Access	No	Yes
Access Reviews	No	Yes
Identity Protection	No	Yes
App Management Policies	Yes	Yes
App Health Recommendations	Yes	Yes
MDA App Governance	Add-on to MDA, free for E5 customers (since June 1 st , 2023)	



HYBRID
IDENTITY
PROTECTION

conf26

FRANKFURT

Summary

Summary & take aways



Consider secure implementation of authentication library, storing credentials and token caching
Avoid long-term credentials and verify security of trusted entities for Workload Identity Federation
Implement application management policy to govern credential issuing



Implement an application and lifecycle management
Consider Entra roles and ownership with permissions on application/service principal objects
Classify your application to detect privilege escalation paths and sensitivity of workload identity



Apply Conditional Access Policies for Service Principals and monitor risk detection
Monitor used/unused permissions and activity (IP address and type of access) after AuthN/AuthZ
Implement playbooks to automate response on suspicious sign-in or activity of service principals



Deploy rule templates and integrate MDA App Governance
Build detection to build correlation and enrichment by classification data
Monitor trusted entities/IdP (for Federated Credentials) and resources with assigned MSI particularly
Review and integrate enriched data by OAuthAppInfo and IdentityInfo

Questions?

Thank you!